IT and Information Security Policy

Contoso Ltd. | Version 2.4 | Effective March 1, 2026 | Synthetic sample document for testing

1. Purpose and Scope

This policy defines the rules that protect Contoso's systems, devices, and data. It applies to all employees, contractors, and interns who access Contoso systems from any location. The IT Security team owns this policy and can be reached at security@contoso.example or on the 24/7 IT Security Hotline, extension 5555.

2. Password Requirements

- Passwords must be at least 14 characters long and include a mix of upper case, lower case, numbers, and symbols, or be a passphrase of four or more unrelated words.
- Passwords must be changed every 180 days, and immediately if compromise is suspected.
- The last 10 passwords may not be reused.
- Employees must never share passwords with anyone, including colleagues, managers, and IT staff. IT staff will never ask for your password.
- Passwords must not be written down or stored in plain-text files. Use the company-approved password manager.
- After 5 failed login attempts, the account is locked for 30 minutes.

3. Multi-Factor Authentication (MFA)

MFA is mandatory for all corporate email, VPN, cloud applications, and administrative accounts. The approved method is the Contoso Authenticator mobile app. SMS-based codes are not permitted. Employees with administrator privileges must also use a hardware security key. If an MFA device is lost or stolen, the employee must report it to IT Security within 4 hours so that it can be revoked.

4. Device Usage

- Company laptops must have full-disk encryption enabled and must lock automatically after 5 minutes of inactivity.
- Operating system and security updates must be installed within 7 days of release.
- Personal devices may access company email only after enrollment in Mobile Device Management (MDM).
- USB storage devices and personal cloud storage services are prohibited for company data.

- Lost or stolen devices must be reported to IT Security within 1 hour of discovery.
- Only software from the approved software catalog may be installed. Other software requires an IT exception request.

5. Access Control

Access to systems follows the principle of least privilege: employees receive only the access required for their role. Access requests are submitted through the IT Service Portal and must be approved by both the employee's line manager and the system owner. Access rights are reviewed every quarter. When an employee leaves Contoso, all access is removed within 24 hours of their last working day.

Data classification

- **Public:** Information approved for public release. No restrictions
- **Internal:** General business information. Share only inside Contoso
- **Confidential:** Customer data, contracts, financials. Encrypt in transit and at rest; share on a need-to-know basis
- **Restricted:** Employee personal data, security credentials. Access only by named individuals; all access is logged

6. Remote Access

Employees working outside the office must connect to the corporate VPN before accessing internal systems. Public Wi-Fi may only be used with the VPN enabled. Work must not be performed on shared or public computers.

7. Reporting Security Incidents

All suspected security incidents must be reported to IT Security within 1 hour of discovery. Examples include phishing emails, malware, lost devices, unauthorized access, and accidental disclosure of data.

What to do after a suspected phishing attack

- Do not click any links, open attachments, or reply to the message.
- Report the email using the 'Report Phishing' button in the email client, or forward it to phishing@contoso.example.
- If you already clicked a link or entered credentials: disconnect the device from the network immediately, change your password from a different device, and call the IT Security Hotline at extension 5555.
- IT Security will investigate and may reset your credentials and scan your device.

- Do not delete the email until IT Security confirms that it is no longer needed as evidence.

8. Security Awareness Training

All employees must complete security awareness training within 30 days of joining and every 12 months thereafter. Employees who fail simulated phishing tests three times in a row must retake the training.

9. Policy Violations

Violations of this policy may result in disciplinary action, up to and including termination of employment and, where applicable, legal action. Exceptions to this policy must be approved in writing by the Chief Information Security Officer (CISO).